

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

TSEC-FREE-008

NYDFS Part 500 Readiness Checklist

Pre-Assessment Readiness Tool — NYDFS Cybersecurity Regulation

23 NYCRR Part 500 (Amended 2023)

Document ID:	TSEC-FREE-008
Version:	1.0
Date:	June 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

www.tsecgrc.com | info@tsecgrc.com

1. Purpose & Instructions

This checklist assesses readiness against the New York Department of Financial Services (NYDFS) Cybersecurity Regulation, 23 NYCRR Part 500, as amended in 2023. It is applicable to Covered Entities and Class A Companies as defined under the regulation. Mark each item ✓ (Compliant), X (Gap), or NA (Not Applicable).

2. Cybersecurity Program (§500.2)**§500.2 — Cybersecurity Program**

#	Control / Requirement	Status (✓/X/NA)
1	A cybersecurity program is established based on a risk assessment.	
2	The program protects the CIA of Nonpublic Information (NPI) and IT systems.	

3	The program is reviewed and updated annually or upon material change.	
4	The CISO (or equivalent) provides an annual report to the Board.	

3. Cybersecurity Policy (§500.3)

§500.3 — Cybersecurity Policy		
#	Control / Requirement	Status (✓/X/NA)
1	A written cybersecurity policy approved by senior management or Board is in place.	
2	The policy covers: information security, data governance, access controls, incident response, and vendor management.	
3	The policy is reviewed at minimum annually.	

4. Access Controls & Identity (§500.7)

§500.7 — Access Privileges & MFA		
#	Control / Requirement	Status (✓/X/NA)
1	Privileged access is limited based on need and reviewed at least annually.	
2	Multi-factor authentication (MFA) is implemented for all remote access.	
3	MFA is implemented for access to nonpublic information via web applications.	
4	MFA is required for all privileged user access (Class A: mandatory).	
5	Shared/generic accounts are prohibited except where technically unavoidable.	

5. Risk Assessment (§500.9)

§500.9 — Risk Assessment		
#	Control / Requirement	Status (✓/X/NA)
1	A formal cybersecurity risk assessment is performed at least annually.	
2	The risk assessment informs the cybersecurity program and controls.	
3	Risk assessment methodology is documented and repeatable.	
4	Risk treatment decisions and residual risk acceptance are documented.	

6. Incident Response & Notification (§500.17)

§500.17 — Notification Requirements

#	Control / Requirement	Status (✓/X/NA)
1	An Incident Response Plan is documented and tested annually.	
2	The organization can detect and respond to cybersecurity events promptly.	
3	NYDFS is notified within 72 hours of a qualifying cybersecurity event.	
4	Annual Certification of Compliance is submitted to NYDFS (Class A: detailed).	
5	Extortion payments related to cybersecurity events are reported within 24 hours.	

7. Third-Party / Vendor Security (§500.11)**§500.11 — Third-Party Service Provider Security**

#	Control / Requirement	Status (✓/X/NA)
1	Policies and procedures for managing third-party cybersecurity risk are documented.	
2	Minimum cybersecurity practices are required from all applicable third parties.	
3	Third-party access is reviewed at least annually.	
4	A third-party vendor inventory is maintained.	

8. Remediation Tracker

§ Ref	Gap Description	Remediation Action	Owner	Due Date